

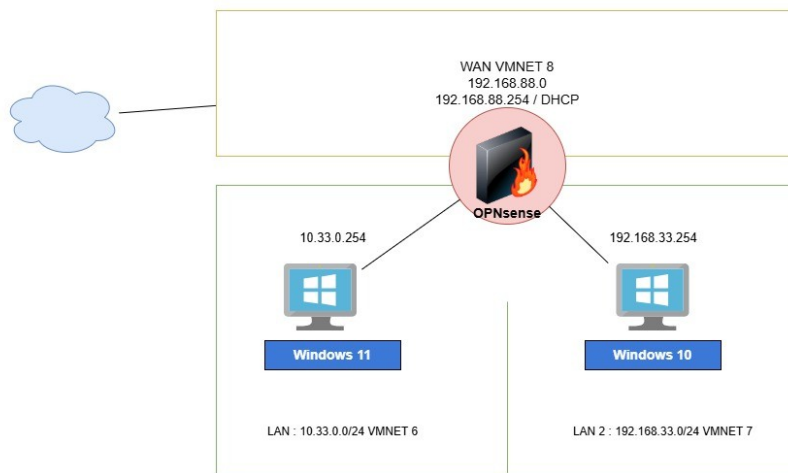
COMPRENDRE ET CONFIGURER UN FIREWALL

Résumé de formation (LinkedIn Learning) & mise en pratique personnelle

Ce document reprend, partie par partie, les points clés de la formation "Comprendre et configurer un firewall", et fait le lien avec ce que j'ai concrètement mis en place sur mes maquettes (OPNsense et FortiGate) ainsi que sur mon poste Windows. Chaque section indique si le point a été appliqué (avec capture d'écran à l'appui) ou s'il reste à pratiquer.

Topologie du lab

Les captures OPNsense de ce document proviennent du lab suivant : un firewall OPNsense virtualisé, avec une interface WAN sur le réseau VMNET8 (192.168.88.0, DHCP), et deux réseaux LAN internes distincts, chacun avec sa propre machine de test.



Topologie du lab : OPNsense entre le WAN (VMNET8) et deux LAN — Windows 11 sur 10.33.0.0/24, Windows 10 sur 192.168.33.0/24

- LAN (VMNET6) : 10.33.0.0/24 — passerelle 10.33.0.254 — poste Windows 11.
- LAN 2 (VMNET7) : 192.168.33.0/24 — passerelle 192.168.33.254 — poste Windows 10.
- Les deux réseaux sont volontairement séparés pour pouvoir tester des règles de filtrage entre eux, comme illustré dans la partie 2.

1. Comprendre le rôle et les fonctions d'un firewall

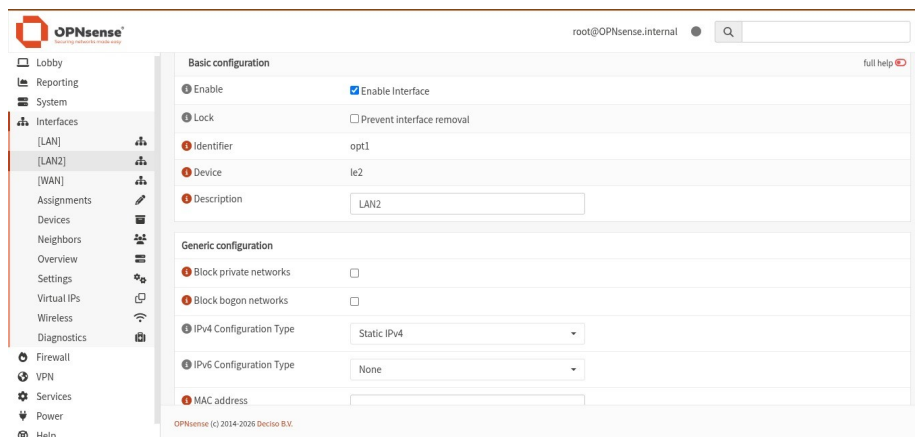
Ce que j'ai retenu

- La cybermenace regroupe plusieurs familles de risques : malwares/ransomwares, phishing, intrusions exploitant des vulnérabilités connues, et attaques par déni de service (DDoS).
- Un firewall agit sur deux plans : le contrôle des flux (autoriser/interdire entre réseaux) et une couche d'intelligence de plus en plus poussée (reconnaissance de signatures d'attaque, limitation de débit/connexions).
- Principe fondateur : "tout ce qui n'est pas explicitement autorisé est interdit" — mais en pratique, la configuration par défaut autorise le trafic sortant et bloque l'entrant.

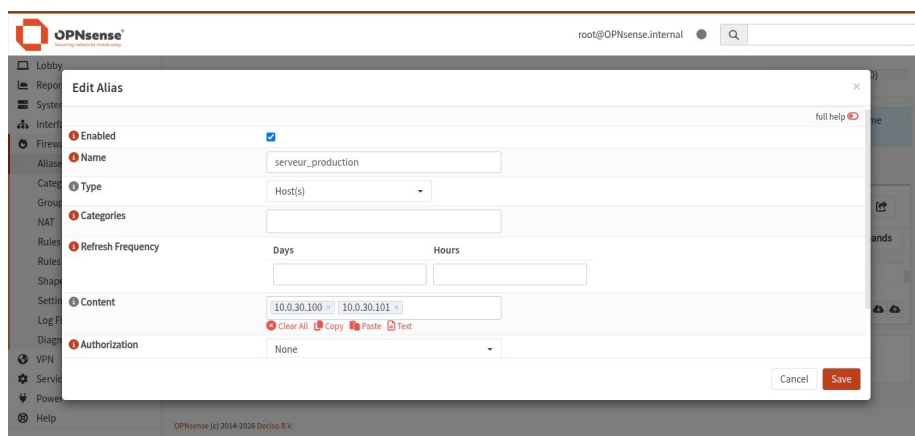
- Notion théorique — pas de mise en pratique associée sur ce module**

- ## ✓ Appliqué — captures à l'appui

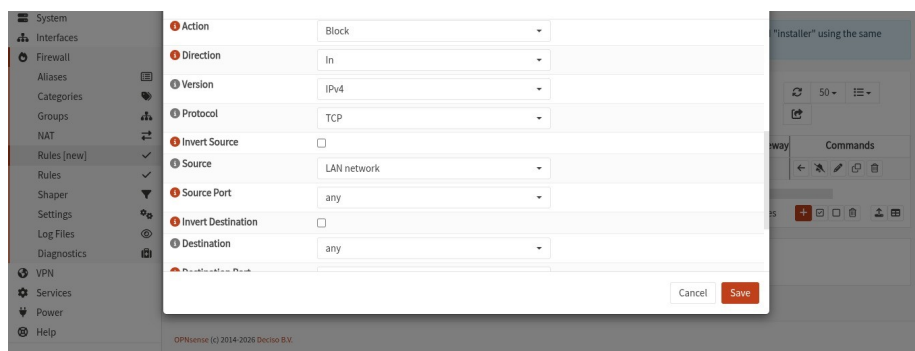




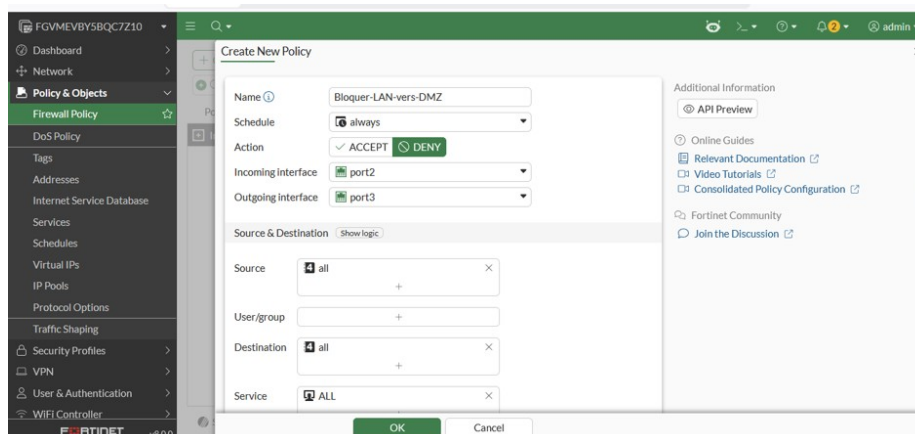
Configuration IP statique de l'interface LAN2 (OPNsense)

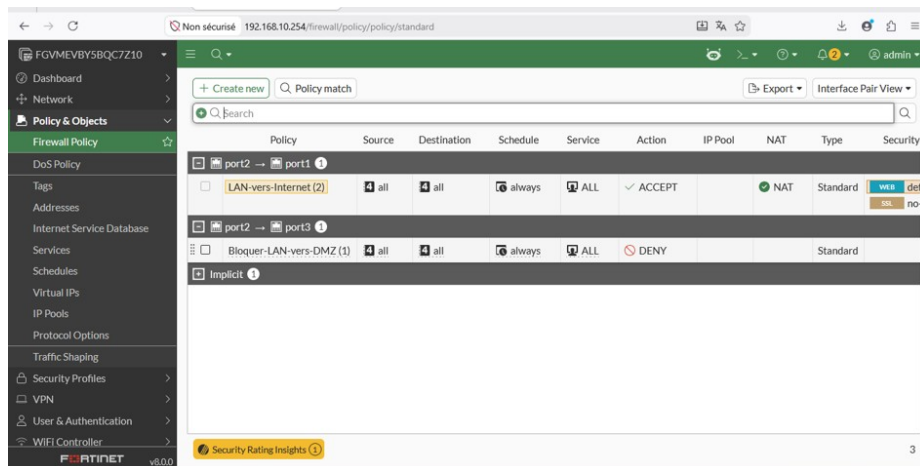


Création d'un alias regroupant plusieurs hôtes (serveur_production) pour simplifier l'écriture des règles



Création d'une règle de blocage (Block, entrant, TCP, source LAN)





FortiGate — vue d'ensemble des politiques : accès Internet autorisé (NAT) et LAN → DMZ bloqué

3. Protéger le réseau des menaces extérieures

Ce que j'ai retenu

- La redirection de port (port forwarding) permet d'exposer un service interne vers l'extérieur : une requête arrivant sur le WAN, sur un port donné, est renvoyée vers une IP et un port internes précis.
- WireGuard est une alternative plus simple et plus légère à OpenVPN pour l'accès nomade : chaque client dispose d'une paire de clés et d'une IP dédiée dans un sous-réseau VPN propre.
- Deux règles de firewall distinctes sont nécessaires : une pour autoriser le port UDP du service VPN sur le WAN, une autre pour définir ce que les clients connectés au VPN ont le droit d'atteindre une fois le tunnel monté.
- Point technique à ne pas oublier : ajuster la taille maximale des paquets (normalisation MTU) pour éviter la fragmentation avec WireGuard.

À pratiquer prochainement — pas encore testé sur ma maquette

4. Tester l'efficacité des fonctions configurées et dépanner un firewall

Ce que j'ai retenu

- Des outils de scan externe (Nmap/Zenmap, Nping) permettent de vérifier, depuis l'extérieur, quels ports sont réellement exposés — utile pour valider une redirection de port ou détecter un oubli.
- Netcat permet d'émuler un service en écoute sur une machine et de tester, depuis une autre, si un port est réellement ouvert entre deux réseaux internes.
- La table des sessions/états du firewall montre, pour chaque connexion en cours, quelle règle la traite réellement — un réflexe clé quand une règle "ne marche pas" comme prévu.
- L'analyse des logs (filtrage par IP, port, règle) permet de confirmer précisément quelle règle bloque ou autorise un paquet, et de corriger l'ordre ou la portée d'une règle.

✓ Partiellement appliqué — vérification par les logs

Date/Time	Source	Device	Destination	Application Name	Result	Policy ID
2026/05/07 00:17:31	192.168.10.50		10.0.0.10	PING	Deny	Bloquer-LAN-vers-DMZ (1)
2026/05/07 00:17:26	192.168.10.50		10.0.0.10	PING	Deny	Bloquer-LAN-vers-DMZ (1)
2026/05/07 00:17:21	192.168.10.50		10.0.0.10	PING	Deny	Bloquer-LAN-vers-DMZ (1)
2026/05/07 00:17:16	192.168.10.50		10.0.0.10	PING	Deny	Bloquer-LAN-vers-DMZ (1)
2026/05/07 00:17:11	192.168.10.50		10.0.0.10	PING	Deny	Bloquer-LAN-vers-DMZ (1)
2026/05/07 00:17:06	192.168.10.50		10.0.0.10	PING	Deny	Bloquer-LAN-vers-DMZ (1)
2026/05/07 00:17:01	192.168.10.50		10.0.0.10	PING	Deny	Bloquer-LAN-vers-DMZ (1)
2026/05/07 00:16:56	192.168.10.50		10.0.0.10	PING	Deny	Bloquer-LAN-vers-DMZ (1)
2026/05/07 00:16:51	192.168.10.50		10.0.0.10	PING	Deny	Bloquer-LAN-vers-DMZ (1)
2026/05/07 00:16:46	192.168.10.50		10.0.0.10	PING	Deny	Bloquer-LAN-vers-DMZ (1)
2026/05/07 00:16:41	192.168.10.50		10.0.0.10	PING	Deny	Bloquer-LAN-vers-DMZ (1)
2026/05/07 00:16:36	192.168.10.50		10.0.0.10	PING	Deny	Bloquer-LAN-vers-DMZ (1)
2026/05/07 00:16:31	192.168.10.50		10.0.0.10	PING	Deny	Bloquer-LAN-vers-DMZ (1)

Logs FortiGate confirmant que la règle « Bloquer-LAN-vers-DMZ » s'applique bien (pings refusés)

Reste à pratiquer : scans Nmap/Nping et Netcat entre réseaux internes

5. Configurer les fonctions réseau avancées

Ce que j'ai retenu

- Le portail captif force l'affichage d'une page de connexion avant l'accès à Internet — typique du wifi invité, avec traçabilité des connexions (obligation légale dans certains contextes).
- L'authentification peut reposer sur une base locale ou un annuaire externe (LDAP/Active Directory), avec une gestion par groupes d'utilisateurs.
- Le portail est personnalisable via un template HTML que l'on peut modifier puis importer sur le firewall.
- Le VPN site à site (IPsec) entre deux firewalls différents exige un alignement précis des paramètres de phase 1 (chiffrement, hachage, groupe Diffie-Hellman, durée de vie) et de phase 2 (réseaux concernés) des deux côtés du tunnel.

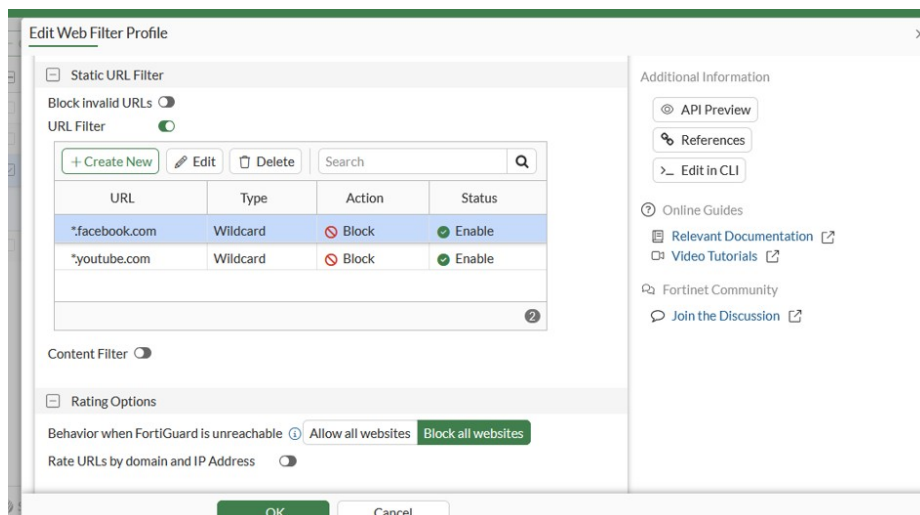
À pratiquer prochainement — pas encore testé sur ma maquette

6. Profiter de l'intelligence embarquée sur son firewall

Ce que j'ai retenu

- Le filtrage web (URL) propose plusieurs modes d'inspection du HTTPS : le mode "certificate-inspection" se contente de lire le nom de domaine échangé en clair au début de la connexion, tandis que le mode "deep-inspection" place le firewall en position d'intercepteur (nécessite de déployer un certificat sur chaque poste).
- Le contrôle applicatif (Application Control) va plus loin que le filtrage web : il reconnaît l'application réelle utilisée (Spotify, LinkedIn, Teams...) même en HTTPS, et peut la bloquer indépendamment du nom de domaine.
- La protection anti-DDoS/anti-scan (DoS Policy) fonctionne par seuils configurables (ex. nombre de pings par seconde, détection de scan de ports), à tester d'abord en mode Monitor avant de passer en Block.
- Il est possible de créer ses propres signatures IPS, en plus des milliers de signatures fournies par défaut, pour cibler un comportement réseau très précis.

✓ Appliqué — capture à l'appui



Profil de filtrage web FortiGate bloquant facebook.com et youtube.com

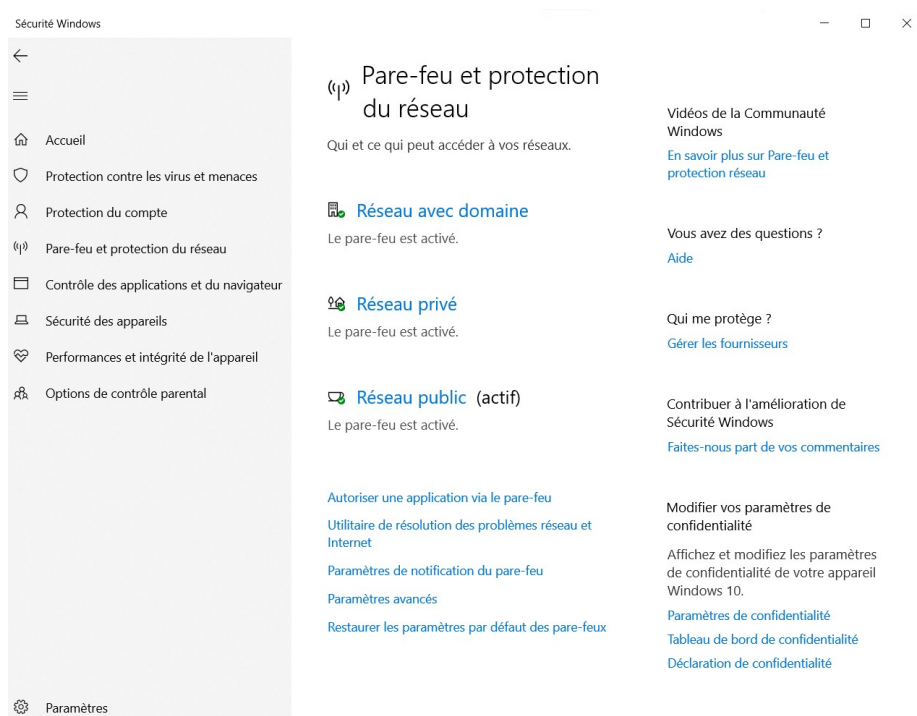
Reste à pratiquer : contrôle applicatif, anti-DDoS et signatures IPS personnalisées

7. Protéger un poste de travail ou un serveur avec un firewall logiciel

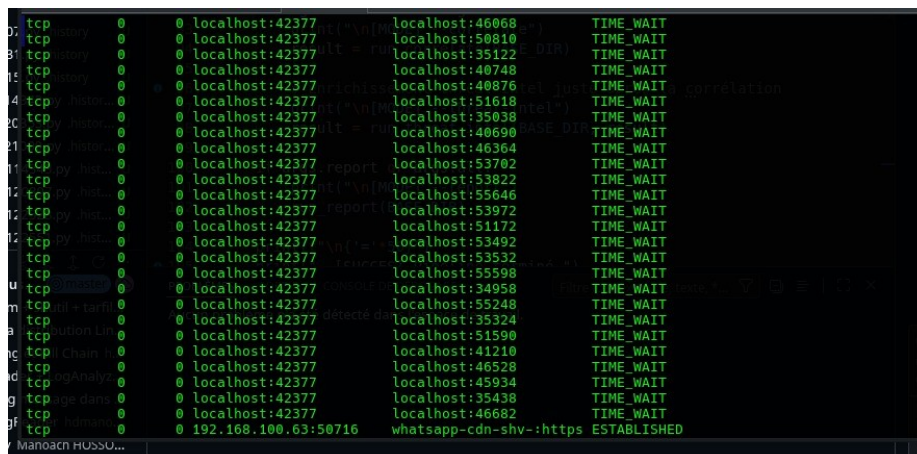
Ce que j'ai retenu

- Windows Defender Firewall applique des règles différentes selon le profil réseau (Public, Privé, Domäne) — le profil Public est nettement plus restrictif par défaut.
- On peut autoriser une application au cas par cas selon le profil réseau, ou bloquer d'un coup toutes les connexions entrantes (utile en cas de suspicion d'incident).
- Des outils comme Netstat (ligne de commande), TCPView ou LiveTcpUdpWatch (Sysinternals/NirSoft) permettent de visualiser en temps réel les connexions actives d'une machine et de repérer une activité suspecte.

✓ Appliqué — captures à l'appui



Pare-feu Windows Defender activé sur les profils Domaine, Privé et Public



Surveillance des connexions réseau actives via un utilitaire type Netstat/TCPView

Bilan

Sur les 7 parties de la formation, j'ai déjà mis en pratique concrètement les parties 2, 6 et 7 (règles de base, filtrage web, firewall poste de travail), partiellement la partie 4 (analyse de logs). Il me reste à pratiquer les parties 3 et 5 (VPN nomade, VPN site à site, portail captif) ainsi que certains outils de test de la partie 4. Prochaine étape : continuer la mise en pratique sur ces points avant de partager un retour d'expérience complet.